

# Endpoint Configuration and Maintenance



# Endpoint Configuration and Maintenance

- Endpoint Configuration Best Practices
- Patch Management and System Updates



# Labs

- Implementing Endpoint Hardening Techniques



# Endpoint Configuration and Maintenance

- Endpoint configuration and maintenance in MDE is a continuous lifecycle process that ensures endpoints remain **hardened, compliant, detectable, and resilient** against evolving threats.
- This includes:
  - ✓ Secure configuration baseline
  - ✓ Policy enforcement
  - ✓ Continuous monitoring
  - ✓ Vulnerability remediation
  - ✓ Agent health validation
  - ✓ Update & signature management
  - ✓ Incident-driven configuration tuning



# Endpoint Onboarding

- Endpoints must be onboarded correctly to enable telemetry flow into the Defender XDR portal.
- Supported onboarding methods:
  - Local script (for testing/lab)
  - Group Policy (GPO)
  - Microsoft Intune
  - Configuration Manager (MECM)
  - VDI onboarding package



# Endpoint Onboarding

- Key verification steps:
  - Device appears in Defender portal
  - Sensor health = Active
  - EDR in block mode (if AV passive)
  - Tamper Protection enabled



# Security Baseline & Hardening

## A. Antivirus Configuration

- Real-time protection: Enabled
- Cloud-delivered protection: Enabled
- Automatic sample submission: Enabled
- Behavior monitoring: Enabled

## B. Attack Surface Reduction (ASR) Rules

- Critical ASR rules:
  - Block Office from creating child processes
  - Block credential stealing from LSASS
  - Block executable content from email/webmail
  - Block persistence via WMI event subscription

These rules significantly reduce ransomware and initial access vectors.

# Policy Management

- Policies can be deployed via:
  - Microsoft Intune
  - Group Policy
  - Microsoft Defender for Endpoint security settings management
- Key policy areas:
  - Antivirus
  - EDR settings
  - Firewall
  - Web protection
  - Device control (USB restrictions)
  - Exploit Guard





# Update & Signature Management

- Endpoint maintenance requires consistent updates:

## A. Security Intelligence Updates

- Frequency: Multiple times daily
- Validate via: `Get-MpComputerStatus | select AntivirusSignatureLastUpdated`

## B. Platform Updates

- Defender platform version must remain supported
- Validate: `Get-MpComputerStatus | select AMProductVersion`

# Update & Signature Management

## C. Engine Updates

- Ensure scanning engine is up-to-date to detect latest threat families.
- Failure to update leads to:
  - Detection gaps
  - False negatives
  - Compliance issues



# Threat & Vulnerability Management (TVM)

- Using the TVM module in Microsoft Defender for Endpoint:
- Monitor:
  - Exposure score
  - Secure score recommendations
  - Missing patches
  - Weak configurations
  - Installed vulnerable software
- Maintenance actions:
  - Prioritize high exposure CVEs
  - Automate remediation through Intune
  - Track remediation completion rate



# Endpoint Health Monitoring

- Continuous monitoring ensures the sensor and protections are operational.

- Monitor:

- Sensor health status
- Antivirus health
- Last seen timestamp
- Onboarding status
- Tamper protection state

Common issues:

- EDR service stopped
- Defender AV disabled by third-party AV
- Outdated sensor version
- Network connectivity blocked (proxy misconfig)

# Automation & Maintenance Optimization

- Use:
  - Automated Investigation & Remediation (AIR)
  - Live Response for remote diagnostics
  - Custom detection rules (KQL)
  - Device groups for policy segmentation
- Advanced Hunting can monitor configuration drift:
- Example query:

```
DeviceTvmSecureConfigurationAssessment  
| where IsCompliant == 0
```



# Compliance & Reporting

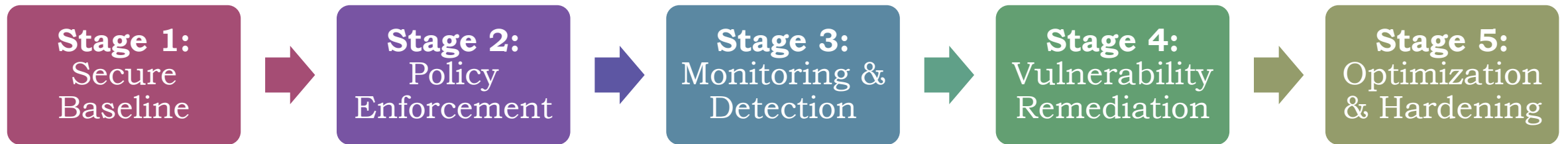
- Track:
  - Endpoint coverage %
  - ASR adoption %
  - Signature currency %
  - Vulnerability remediation SLA
  - Secure Score trend
- Integration with:
  - Microsoft Sentinel for SIEM-level visibility
  - Microsoft Defender XDR for cross-domain correlation



# Operational Best Practices

- Enable Tamper Protection
- Use EDR in Block Mode
- Deploy ASR in Audit → then Enforce
- Maintain minimum 98% sensor health
- Automate patch remediation
- Review exposure score weekly
- Validate onboarding for new devices daily

# Endpoint Configuration Lifecycle Model



Repeat continuously.



# Endpoint Configuration Best Practices

- **Establish a Hardened Security Baseline**
  - Microsoft Security Baseline, CIS-aligned configurations
- **Enable EDR in Block Mode**
  - Allows Defender to remediate post-breach artifacts
  - Prevents reliance solely on primary AV engine
- **Enforce Attack Surface Reduction (ASR)**
  - Block Office creating child processes, Block credential stealing from LSASS
- **Protect Credentials**
  - Windows Defender Credential Guard, LSASS protection



# Endpoint Configuration Best Practices

- **Network & Firewall Hardening**

- Windows Defender Firewall (all profiles), Outbound filtering for sensitive segments

- **Device Control & Peripheral Management**

- USB storage access, Unauthorized removable media

- **Patch & Vulnerability Management Discipline**

- Exposure score trend, Remediation velocity

- **Maintain Sensor & Signature Health**

- Sensor health status, Last seen timestamp
- Platform version, Engine version



# Endpoint Configuration Best Practices

- **Enable Tamper Protection**

- Disabling real-time protection
- Modifying registry-based Defender settings

- **Role-Based Access Control (RBAC)**

- Restrict portal access by → Device group, Role, Geography

- **Incident-Driven Configuration Optimization**

- Identify missed prevention controls, Strengthen ASR

- **Segmentation & Device Group Strategy**

- Business function, Risk profile

# Endpoint Configuration Best Practices

- **Logging & Telemetry Optimization**

- Full EDR telemetry enabled, Advanced audit policy configured

- **Continuous Validation**

- Alert generation, Automated remediation

- **Configuration Governance Model – Implement**

Quarterly:

- ASR review
- Exposure score review
- Policy drift audit

Monthly:

- Vulnerability trending
- Endpoint health report
- Sensor validation

Weekly:

- Signature freshness check
- High-risk alert review

# Patch Management and System Updates

- Patch Management is the structured process of **identifying, acquiring, testing, deploying, and verifying updates to operating systems, applications, and firmware** in order to remediate vulnerabilities, improve stability, and maintain compliance.
- Patch management is the systematic process of identifying, testing, and deploying software updates (patches) to fix bugs, close security vulnerabilities, and improve performance, balancing security with operational stability to maintain system health, ensure compliance (like HIPAA/GDPR), and prevent costly breaches or downtime



# Patch Management

- A mature patching strategy must:
  - Reduce attack surface
  - Remediate known CVEs within SLA
  - Maintain OS and application stability
  - Ensure Defender platform compatibility
  - Maintain compliance posture
- **Unpatched systems remain the most common initial access vector** (especially for privilege escalation and RCE).

# Patch Categories You Must Manage

## A. Operating System Updates

- Monthly cumulative updates
- Out-of-band emergency patches
- Servicing stack updates
- Feature updates (Windows version upgrades)

## B. Microsoft Application Updates

- Office
- .NET
- SQL Server
- Exchange (on-prem)

## C. Third-Party Software Updates

- Browsers
- PDF readers
- Java
- VPN clients

## D. Security Intelligence & Defender Updates

- Security intelligence (signatures)
- Engine updates
- Platform updates

# Patch Governance Framework

- Example enterprise model:

| <b>Severity</b> | <b>SLA</b> |
|-----------------|------------|
| <i>Critical</i> | 7 days     |
| <i>High</i>     | 14 days    |
| <i>Medium</i>   | 30 days    |
| <i>Low</i>      | 60–90 days |



# Tools for Patch Deployment

- **Cloud-Managed Environments**

- Microsoft Intune for Windows Update for Business policies
- Update rings (pilot → broad → critical systems)

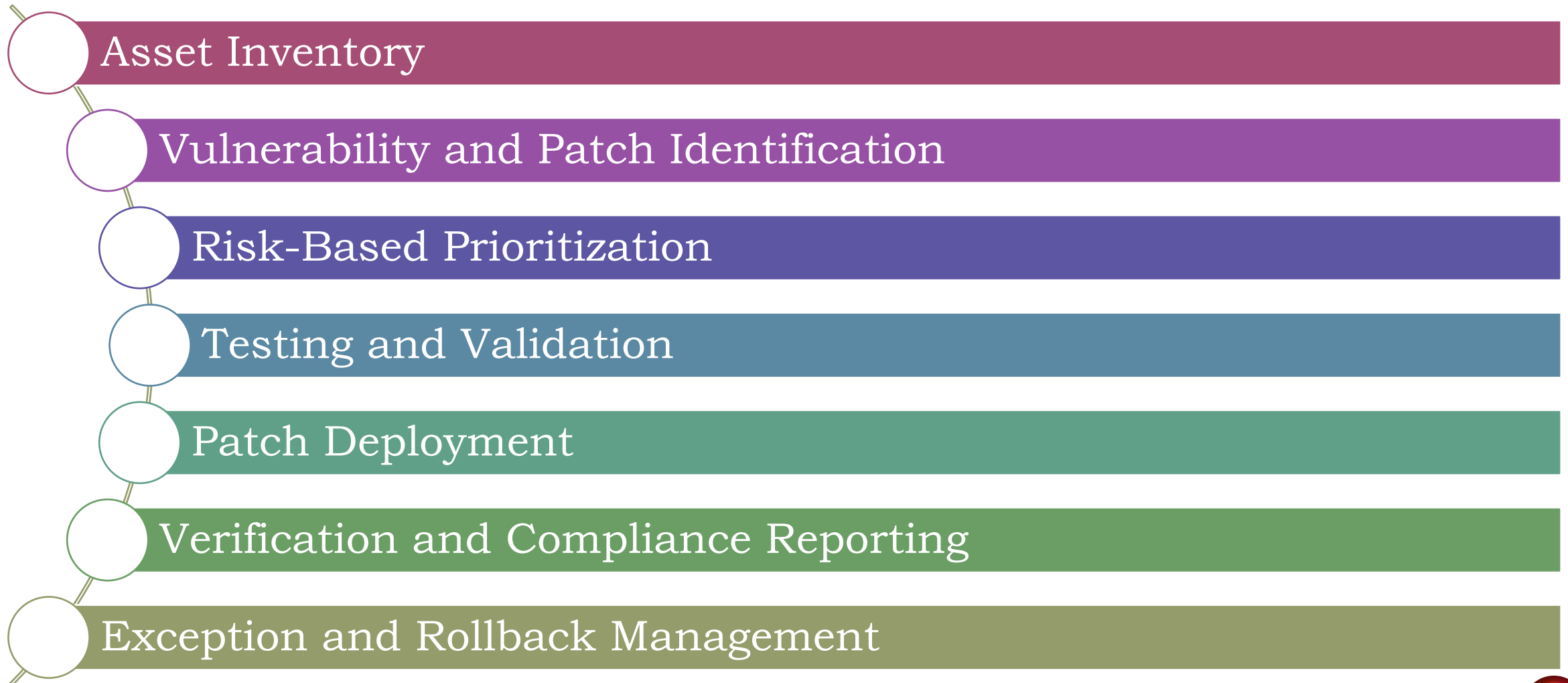
- **Hybrid / On-Prem**

- Microsoft Endpoint Configuration Manager
- WSUS (where still applicable)

- **Vulnerability Visibility**

- Microsoft Defender for Endpoint
- This gives:
  - Exposure score
  - Missing KB tracking
  - CVE impact mapping
  - Business impact prioritization

# Patch Management Lifecycle



# Windows Update Best Practices

- **Configure Update Rings**
- Example structure:
  - **Ring 0** – IT Pilot (1–3 days delay)
  - **Ring 1** – Broad Users (7 days delay)
  - **Ring 2** – Critical Systems (14+ days delay)
- Avoid zero-day deployment unless emergency patch.



# Server Patch Management Considerations

- Servers require stricter controls:
  - Maintenance windows
  - Change approval process
  - Backup before patching
  - Cluster-aware updating (if applicable)
  - Rolling updates for high availability systems
- For domain controllers and critical infrastructure:
  - Patch in staggered sequence
  - Validate replication after update



# Monitoring Patch Compliance

- Track KPIs:
  - Patch compliance %
  - Mean time to remediate (MTTR)
  - Devices missing critical updates
  - Exposure score trend
- Integrate telemetry into:
  - Microsoft Sentinel for centralized compliance dashboards
- Target benchmark:
  - 95%+ compliance within SLA



# Emergency (Zero-Day) Patch Response

- When active exploitation occurs:
  - Identify vulnerable devices immediately
  - Isolate high-risk systems if needed
  - Accelerate deployment timeline
  - Monitor for exploitation indicators
  - Validate remediation success
- Combine patching with:
  - ASR enforcement
  - Temporary firewall hardening
  - Threat hunting



# Common Patch Management Failures

- No pilot testing
- No reboot enforcement
- Ignoring third-party software
- Relying solely on Windows Update reports
- Lack of visibility into failed installations
- No SLA enforcement



# Advanced Strategy: Risk-Based Patching

- Move beyond calendar-based patching.
- Prioritize using:
  - Exploit availability
  - Asset sensitivity
  - Business impact
  - Internet exposure
- This aligns with Zero Trust principles.





# Automation & Optimization

- Enable:
  - Automatic patch deployment rules
  - Auto-remediation via Intune
  - Scheduled compliance reports
  - Automated vulnerability remediation recommendations
- Use Defender TVM to trigger remediation tasks directly.

# Implementing Endpoint Hardening Techniques

- Endpoint hardening reduces attack surface, blocks common adversary TTPs, and increases detection fidelity.
- Hardening must be policy-driven, centrally managed, continuously validated, and aligned to MITRE ATT&CK techniques.
- Primary enforcement platform:
  - Microsoft Defender for Endpoint
- Policy deployment platforms:
  - Microsoft Intune
  - Microsoft Endpoint Configuration Manager



# Establish a Hardened Security Baseline

## Deploy Microsoft Security Baseline

- Apply:
  - Defender AV baseline
  - Firewall baseline
  - Credential protection baseline
  - Audit policy baseline
- Use Intune Security Baselines or Group Policy for domain-joined systems.

# Establish a Hardened Security Baseline

## Critical Settings to Enforce

- Real-time protection: Enabled
- Cloud-delivered protection: Enabled
- Behavior monitoring: Enabled
- Automatic remediation: Enabled
- Network protection: Enabled
- Tamper Protection: Enabled



# Attack Surface Reduction (ASR) Implementation

- ASR directly blocks high-risk attacker behaviours.

- **Phase-Based Deployment**

- Audit mode (7–14 days)
  - Analyze impact
  - Move to Enforce mode

- **High-Priority ASR Rules**

- Block Office from creating child processes
  - Block credential stealing from LSASS
  - Block executable content from email/webmail
  - Block process injection
  - Block persistence via WMI

Apply stricter ASR to:

- Domain controllers
- Admin workstations
- Finance endpoints



# Credential Hardening

- Credential theft remains a dominant lateral movement method.
- **Implement:**
  - Credential Guard
  - LSASS protection (RunAsPPL)
  - Disable WDigest
  - Restrict NTLM
  - Enforce SMB signing
- Monitor in Defender portal for:
  - LSASS memory access attempts
  - Suspicious token manipulation



# Application Control (Allowlisting)

- Use Windows Defender Application Control (WDAC) or AppLocker.
- Purpose:
  - Block unsigned binaries
  - Prevent execution from user-writable paths
  - Stop ransomware droppers
- Best practice:
  - Begin in Audit mode
  - Move to enforced policy gradually
  - Maintain signed application catalog



# Network Hardening

- **Windows Defender Firewall**

- Enable all profiles (Domain, Private, Public)
- Block inbound by default
- Restrict lateral SMB traffic where possible

- **Network Protection**

- Enable network protection in Defender to:
- Block malicious domains
- Prevent C2 callbacks
- Stop phishing infrastructure connections





# Device Control & Peripheral Restrictions

- Mitigate data exfiltration and malware introduction.
- Configure in Defender:
  - Block unauthorized USB storage
  - Allow encrypted corporate USB only
  - Audit removable media usage
  - Restrict Bluetooth file transfer
- Apply differentiated policies by device group.

# Patch & Vulnerability Hardening

- Hardening actions:
  - Patch critical CVEs within 7–14 days
  - Remove unsupported software
  - Disable legacy protocols (SMBv1, TLS 1.0)
  - Remove local admin privileges
- Track:
  - Exposure score
  - Secure score improvement
  - High-risk software footprint



# Privilege & Identity Hardening

- **Enforce Least Privilege**

- Remove local admin rights for standard users
- Use Privileged Access Workstations (PAW)
- Separate admin accounts from user accounts

- **Monitor Privileged Actions**

- Forward telemetry to Microsoft Sentinel
- Alert on:
  - Group membership changes
  - Privilege escalation attempts
  - Unusual logon patterns

# PowerShell & Script Hardening

- Enable:
  - Script block logging
  - Module logging
  - Constrained Language Mode (for non-admin users)
  - Disable PowerShell v2
- This blocks common post-exploitation activity.





*That's all Folks!*